

Read before you sign.

Inside the security review of Elyra for Android: 202 source files, 961 dependencies and every commit in the repository, examined the way an attacker would. This is what we found and how we fixed it.

10	0	6	236
FINDINGS	CRITICAL	FIXED, 1 IMPROVED	TESTS PASSING

THE SHORT VERSION

A wallet app is only as safe as the moment before you sign.

Elyra for Android puts trading, transfers and research on Solana into one app, with a built-in wallet that holds real money. That makes it a target. Before we ask anyone to trust it, we wanted to know what an attacker would find.

So we reviewed the whole Android app: every screen, every link it opens, every byte it signs, every package it depends on and every commit in the repository. We measured it against the industry's mobile security standard, OWASP MASVS v2, and against the threats specific to wallets.

The headline: no critical issues. The core design held up. The app talks to one server, ships no secrets, never writes a sign-in token to disk, and never changes a transaction it was given to sign.

Two issues mattered, and both are fixed. First, the confirm screen showed a description of each transaction, but nothing checked that description against the transaction actually being signed. Second, an exception meant only for developers' test builds let a crafted link skip the app's link checks.

Every fix comes with tests that prove it: 15 new ones, and all 236 pass.

> "Every transfer is now checked on the phone, byte for byte, before any wallet is asked to sign it."
>
> THE CHANGE THAT MATTERS MOST

0

CRITICAL FINDINGS

Nothing that let an attacker act without the person's own confirmation.

0

SECRETS IN GIT

Every commit in the repository was scanned for keys and credentials.

100%

OF FIXES TESTED

Each one is covered by an automated test against real transactions.

BY THE NUMBERS

What a full review actually covers.

202
SOURCE FILES
Every screen, component and module in the Android app.

37
SCREENS
From sign-in to swap, each read with an attacker's eye.

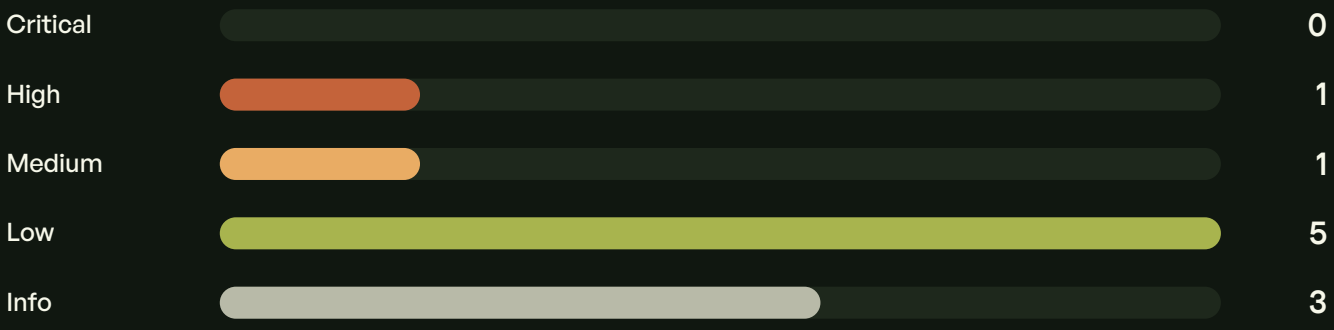
961
DEPENDENCIES
Audited against known advisories.

100%
GIT HISTORY
Every commit, every branch, scanned for leaked secrets.

236
TESTS PASSING
Up from 221. Every fix ships with proof.

8
MASVS GROUPS
Every OWASP mobile control group, from storage to privacy.

FINDINGS BY SEVERITY



6 fixed · 1 improved · 1 tracked · 1 open · 1 accepted by design

FINDING M-01 · FIXED

Read before you sign.

Most mobile wallets show you a summary and trust it. Elyra now reads the transaction itself.

In Elyra, the server builds every transaction and your wallet signs it on the phone. It's a sound design: the hard work happens on the server, and the key never leaves your control. But the built-in wallet signs without a screen of its own, so Elyra's confirm screen is the last thing you see before your signature.

Before this review, that screen showed the server's description of the transfer. If the description and the transaction itself ever disagreed, whether through a bug or a compromised server, nothing would have noticed. Now nothing reaches a wallet until the phone has decoded it and checked it against what you asked for.



THE SIX CHECKS, ON EVERY TRANSFER

Recipient
Exactly the address you typed.

Token
The token you chose, and no other.

Amount
Down to the smallest unit, using the server's own maths.

Signer
Your wallet alone signs and pays the fee.

Network fee
Capped well above normal, and far below harmful.

Instructions
Only what a transfer needs. Anything else is refused.

> **For token transfers, the blockchain enforces the recipient too: the token program refuses any account that doesn't belong to the address you typed. The phone checks that the money goes to that account.**

What's next. Swaps already check that your wallet is the intended signer. Checking Jupiter's full route, which involves programs a phone can't list in advance, moves to the server next.

FINDING H-01 · FIXED

The link that skipped the line.

Deep links are how a tap on a web page opens an app. They are also how phishing starts.

Elyra opens links from outside the app through a strict allowlist: a referral, a market, the wallet, the inbox or a research report. Anything else goes to the home screen. The review found an exception meant only for developers' test builds that also applied to the version in the store.

A link built a particular way could skip the allowlist and open any screen with its fields already filled in. Moving money still needed your own review and confirmation, but a convincing pre-filled screen is what phishing relies on. The exception now exists only in developer builds, and tests prove the store build checks every link.



FINDING L-01 · FIXED

Links that leave the app

Links from market data, filings and research now open only as web pages. A link in third-party data can no longer open your wallet with a payment request already filled in, or launch another app.

FINDINGS L-02, L-03 · FIXED

Small, but signed

Research PDFs download over HTTPS only. When an external wallet signs a message, Elyra checks that the signature covers exactly the message it sent, byte for byte.

WHAT WE GOT RIGHT

Built in from day one.

A review should credit what already works. These controls were in place before it started, and they're the reason the findings list is short.

01
One server. No keys.
The app talks only to Elyra's API. No provider key or secret ships inside it.

02
Tokens stay off disk
Sign-in sessions live in Android's secure storage. Nothing else keeps a token.

03
You sign. Always.
The server builds the transaction and your wallet signs it. The phone never edits the bytes.

04
Wrong wallet? Refused.
A wallet holding a different key is refused before it ever sees the transaction.

05
A walled-off chart
The TradingView chart runs in a locked-down WebView: approved sites only, no file access, no pop-ups.

06
Safe AI answers
Elyra's agent replies are drawn natively, never as HTML, and their links can only open web pages.

07
Notifications verify
Tapping a notification opens a screen only if the notification belongs to the signed-in account.

08
Read-only exchanges
Exchange keys must be read-only. They are masked as you type and never shown again.

09
Crash reports, not you
No user, IP address, screenshot or request body. Addresses, tokens and emails are removed before anything is sent.

10
Minimal permissions
Camera for scanning QR codes, the microphone for dictation, and notifications. Nothing else, and no cloud backup of app data.

11
Leave no trace
Deleting your account clears the phone as well: secure storage, preferences and cache.

12
Clean history
No secret has ever been committed to the code repository. We checked every commit.

THE LEDGER

Every finding, on the record.

All ten findings in the app, ranked by severity, with where each one stands today.

ID	FINDING	SEVERITY	STATUS
H-01	A developer-only link exception also applied to store builds, letting a crafted link bypass the deep-link allowlist	HIGH	FIXED
M-01	Signed transactions were not checked against what the confirm screen showed	MEDIUM	FIXED
L-01	Links from third-party data could open non-web schemes, such as payment requests	LOW	FIXED
L-02	A report download was not restricted to HTTPS	LOW	FIXED
L-03	Wallet-app signature format was not fully validated	LOW	FIXED
L-04	Advisories in build-time dependencies (not in the shipped app)	LOW	TRACKED
L-05	Swap routes are verified for the signer only; full route checks move server-side	LOW	IMPROVED
I-01	No screenshot protection on screens that show balances	INFO	OPEN
I-02	Tighter link parsing and corrected security documentation	INFO	FIXED
I-03	Code obfuscation off by design, to keep wallet SDKs working	INFO	ACCEPTED

HIGH	Exploitable from outside with little interaction, and it weakened a security boundary the app relies on.
MEDIUM	Exploitable only under specific conditions, such as a compromised server.
LOW	Defence in depth, or limited impact.
INFO	A hardening suggestion, not a vulnerability.

There are no critical findings. Issues with the development environment, as opposed to the app, were dealt with privately and aren't listed here. Specifics that could help an attacker have been left out on purpose.

HOW WE CHECKED, AND WHAT'S NEXT

Method, not magic.

SCOPE

The whole Android app: 202 source files across 37 screens, its native and build configuration, 961 dependencies, and the repository's full history.

STANDARD

OWASP MASVS v2, plus the threats that matter most for wallets: being tricked into signing, phishing through links, a compromised server, a dishonest wallet app, and data left behind on a shared phone.

EVIDENCE

Every finding was reproduced or confirmed rather than assumed. Every fix ships with tests, and the transaction tests use real Solana transactions built the same way the server builds them.

APPROACH

An internal review, carried out with AI assistance from Claude Code and checked by automated tests. It is not a third-party audit, and we would welcome one.

OWASP MASVS V2

Storage	PASS
Cryptography	PASS
Authentication	PASS
Network	PASS
Platform	FIXED
Code quality	IMPROVED
Resilience	BY DESIGN
Privacy	PASS

WHAT'S NEXT

01

Swap routes, verified on the server

Full checks on Jupiter swap transactions before they reach your phone.

02

Balances kept off screenshots

Protection against screenshots and the app switcher on screens that show money.

03

Audits on every build

Dependency and secret scanning in continuous integration, and dependency upgrades.

04

The next review

Elyra's API and website, held to the same standard.

Security isn't a launch feature. It's a habit.



Found something? Report it privately to ayushkmrjha@gmail.com · getelyra.xyz